

信息安全
理论、技术、应用

王　勇
cla@uestc.edu.cn
电子科技大学计算机学院

Cla.R

电子科技大学



本章内容

1. 网络攻击的概念（了解）

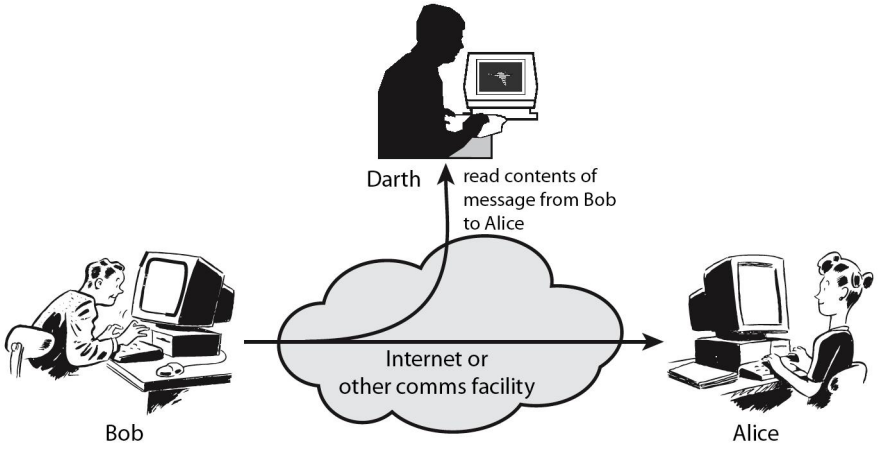
2. 安全服务和安全机制（掌握）

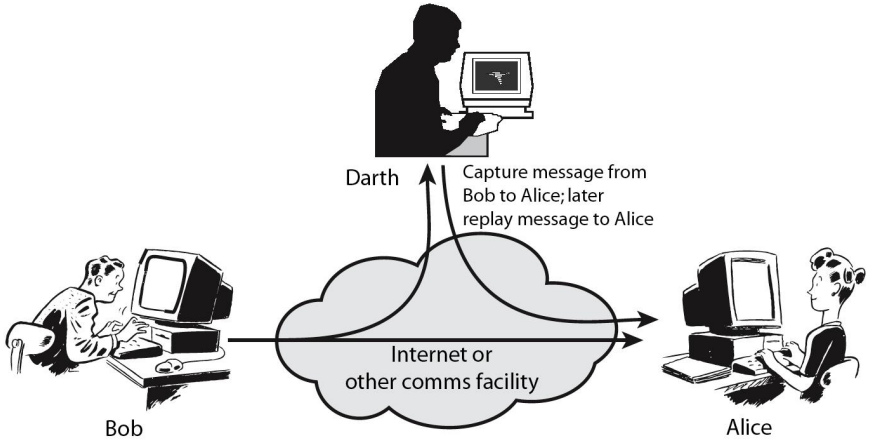
3. 访问控制模型（掌握）



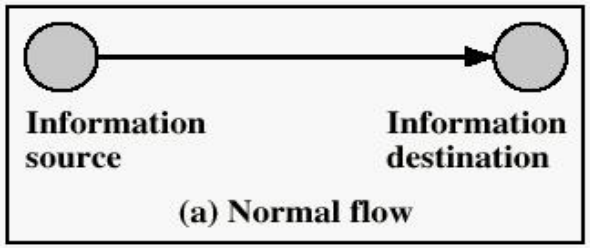
网络攻击的概念

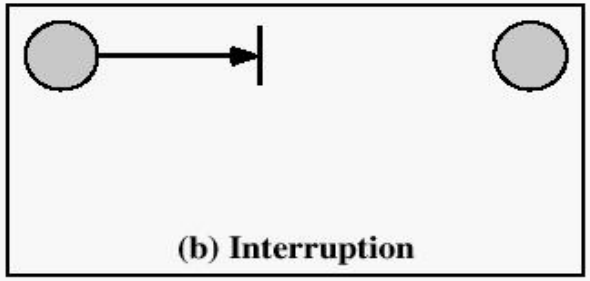
主动攻击和被动攻击

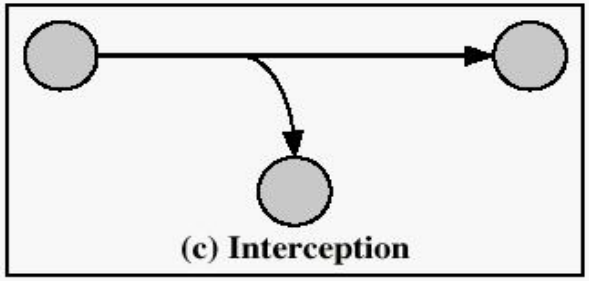


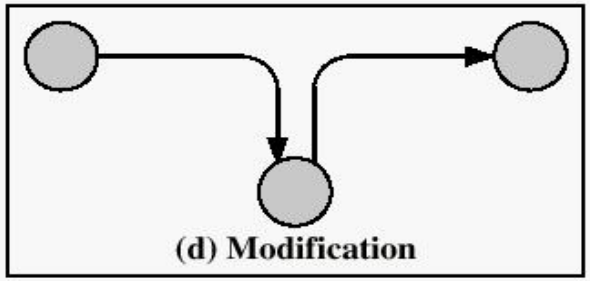


Security Attacks









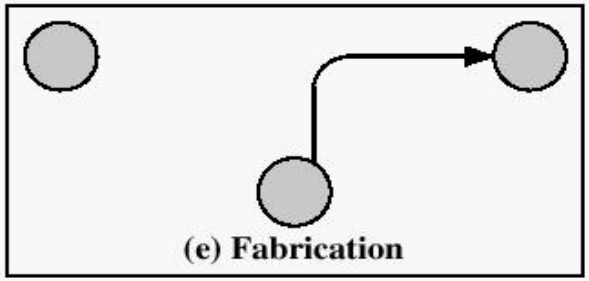
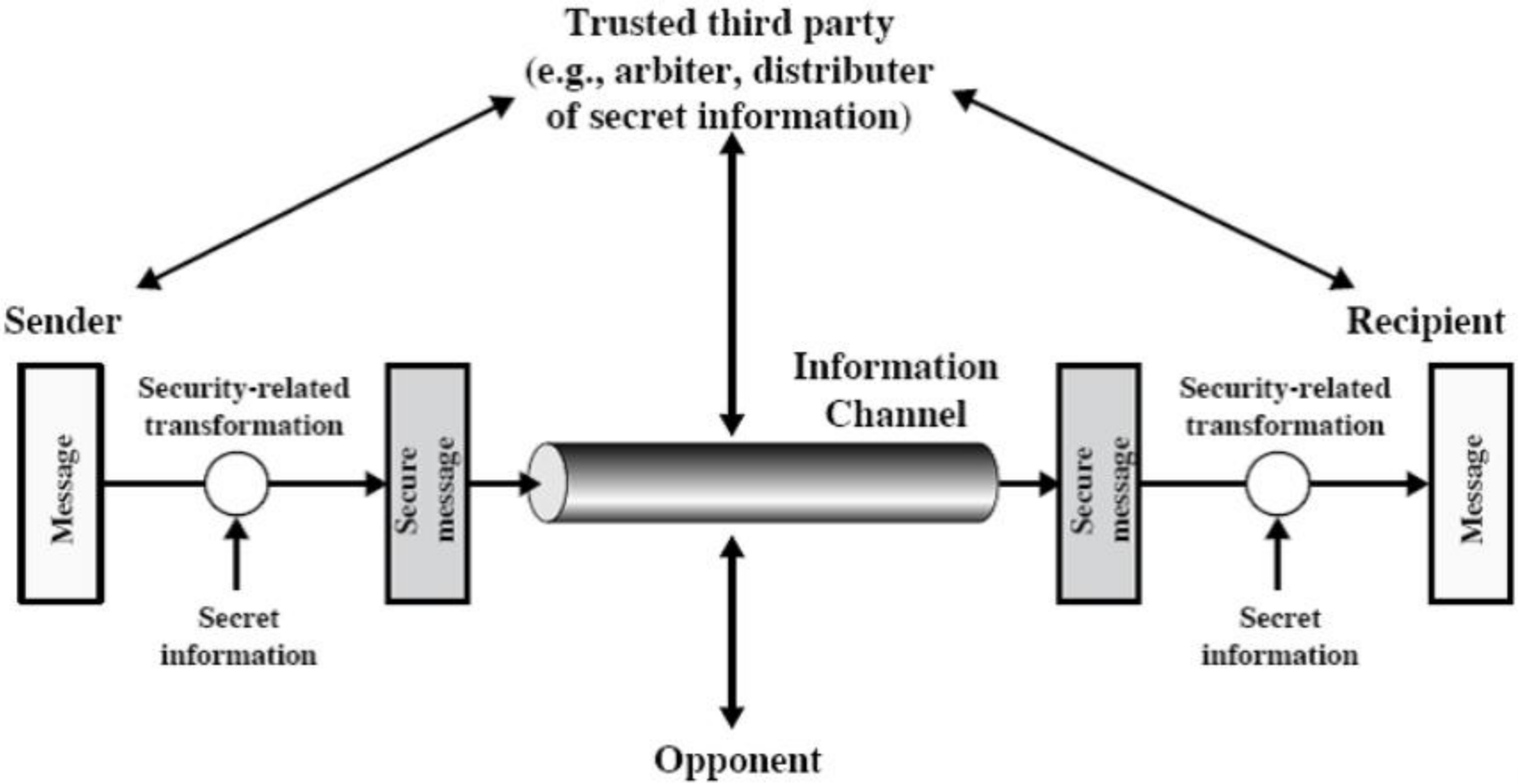


Figure 1.1 Security Threats



信息安全基础模型


Trusted third party
(e.g., arbiter, distributer
of secret information)
Sender
Recipient
Message
Security-related
transformation
Secure
message
Information
Channel
Secure
message
Security-related
transformation
Message
Secret
information
Secret
information
Opponent



信息安全动态模型

P2DR模型

以“策略”为中心，
防护+检测+响应

我们希望:

$$t_p > (t_D + t_R)$$



P2DR模型示意图

Cla.R

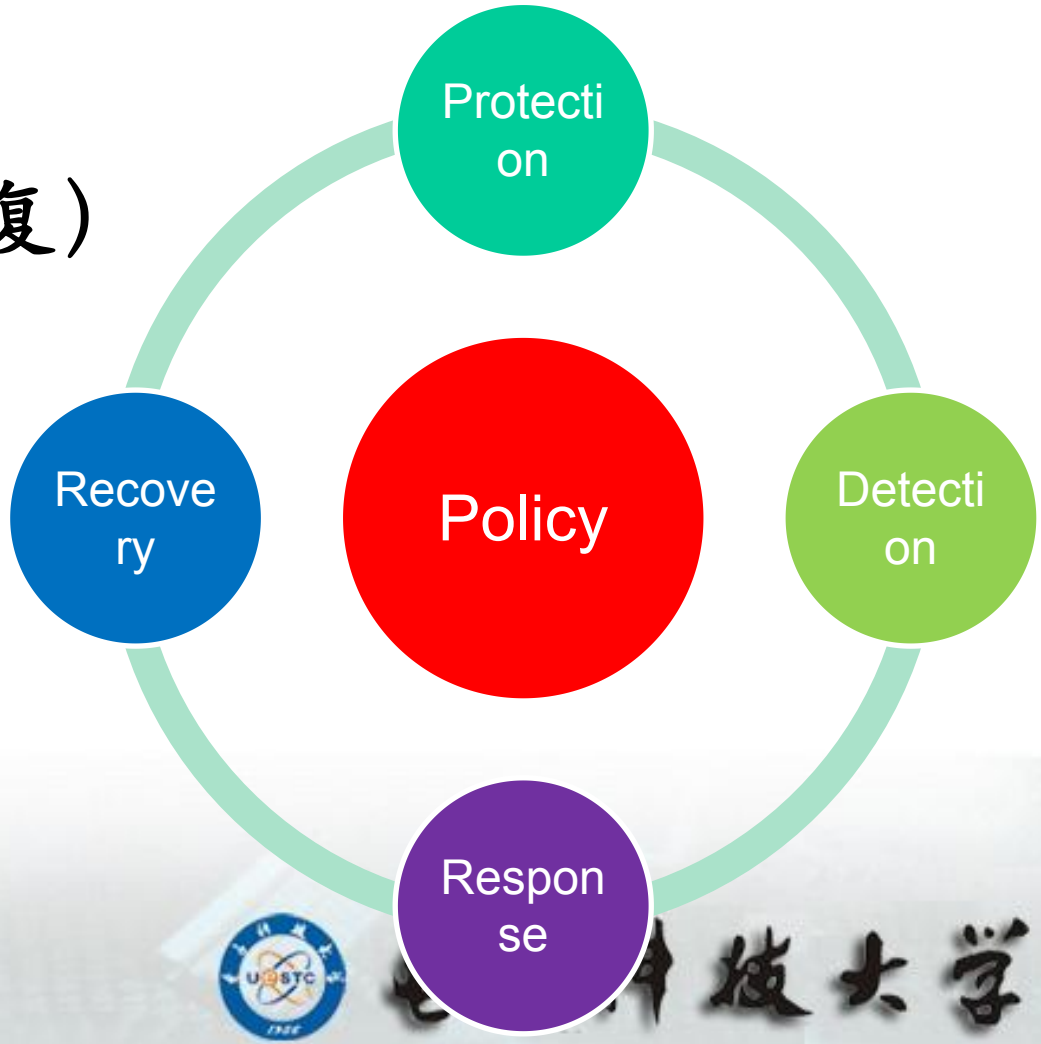
电子科技大学



信息安全动态模型

P2DR2模型

增加了重建（恢复）





安全标准

- BS 7799-1：1995《信息安全管理实施细则》，1995年发布；
- BS 7799-2《信息安全管理体系规范》，1998年发布；
- BS7799-1：1999《信息安全管理实施细则》通过了国际标准化组织ISO的认可，成为国际标准—ISO/IEC17799-1：2000《信息技术——信息安全管理实施细则》，2000年12月发布；
- 《BS7799-3：2005信息安全管理体系，信息安全风险管理指导方针》作为ISO 27001正式颁布，2005年10月发布。



安全服务

安全服务是指

提供数据处理和数据传输安全性的主要安全防护措施，是由参与数据处理和数据传输系统提供的服务（可以是系统的某一层），它确保系统具有足够的安全性。

ISO7498-2确定了五大类安全服务：

(1) 鉴别
(2) 访问控制
(3) 数据机密性
(4) 数据完整性
(5) 抗抵赖



(1) 鉴别

- 信息系统需要同时保护信息的机密性、完整性和可用性。其中，信息的完整性主要通过鉴别服务完成。

- 鉴别分为实体鉴别和消息鉴别两个方面

①实体鉴别：验证通信双方的身份，防止未授权用户使用系统

②消息鉴别：验证信息的完整性，防止消息被篡改、伪造。



(2) 访问控制

- 访问控制：决定谁能够通过何种方式使用系统的什么资源
- 系统资源包括：
  - 信息资源、计算资源、通信资源、物理硬件/软件资源等



(3) 数据机密性

- 机密性是信息安全的基本属性之一，确保数据不会被泄露
- 数据机密性保护分为3类:
  - 隐含语意：加密、数据隐藏
  - 访问控制:
  - 分割和散布数据



(4) 数据完整性

- 数据完整性是指数据未丢失、未篡改，未非授权使用。
- 分为两类
  - 单个数据单元、字段完整性
  - 数据单元流和字段流完整性
- 提供数据完整性服务可以分为三个阶段:
  - 防护（生成受约束数据）
  - 证实（检测完整性）
  - 保护（重新生成数据）

Cia.R



(5) 抗抵赖

①带数据源证明的不可否认

有数据原发证明的抗抵赖服务，防止“发信者”否认

②带递交证明的不可否认

有交付证明的抗抵赖服务，防止“收信人”否认



安全机制

- ISO7498-2确定了八大类安全机制，即：
  - 加密、
  - 数据签名机制、
  - 访问控制机制、
  - 数据完整性机制、
  - 鉴别交换机制、
  - 业务填充机制、
  - 路由控制机制、
  - 公证机制



(1) 加密

①保密性
②加密算法
- 可逆的（有密钥加密算法）
  - 对称(即秘密密钥)加密
  - 非对称(即公开密钥)加密
- 不可逆的（无密钥加密算法）

可用于实现数据机密性服务、认证服务、数据完整性服务和抗抵赖服务



(2) 数字签名机制

- 这种安全机制包含两个过程:
  - 对数据单元签名 – 签名
  - 验证签过名的数据单元 – 签名验证

① 签名

签名过程利用签名者的私有信息作秘密密钥

② 验证

验证过程是利用公开的规程和信息确定签名是否是利用该签名者的私有信息产生的

③ 特征

签名机制的主要特征是签名只有利用签名者的私有信息才能产生出来



(3) 访问控制机制

① 确定访问权

这种安全机制可以利用某个实体经鉴别的身份或关于该实体的信息(如在某个已知实体集里的资格)或该实体的权标，确定并实施实体的访问权。

② 访问控制机制可以建立在下列一个或多个手段之上

a）访问控制信息库；b）权标；c）安全标签;；d）试图访问的时间；e）试图访问的路由；f）访问持续的时间

③ 访问控制机制可用在通信连接任何一端或用在中间任何位置



(4) 数据完整性机制

① 数据完整性机制的两个方面

- 单个数据单元或字段的完整性
- 数据单元串或字段串的完整性

数据完整性机制实现分为两个过程：
（1）生成附加标记；　（2）验证附加标记



(5) 鉴别交换机制

- 这种安全机制采用交换信息的方式来实现同级实体身份之间的鉴别。

- 常用的方式例如： 口令、数据加密确认、数字证书等



(6) 业务填充机制

- 业务填充机制是一种制造假的通信实例、产生欺骗性数据单元或数据单元中假数据的安全机制。
- 该机制可用于提供各种等级的保护，防止业务流量分析。
- 该机制只在业务填充受到保密性服务保护时才有效。



(7) 路由选择控制机制

路由既可动态选择，也可事先安排好，以便只利用物理上安全的子网、中继站或链路。



(8) 公证机制

关于在两个或多个实体间通信的数据的安全性，如它的完整性、来源、时间和目的地等，可由公证机制保证。保证由第三方公证人（TTP）提供，公证人得到通信实体的信任，并且掌握有按照某种可证实方式提供所需保证的必要信息



安全服务与安全机制的关系

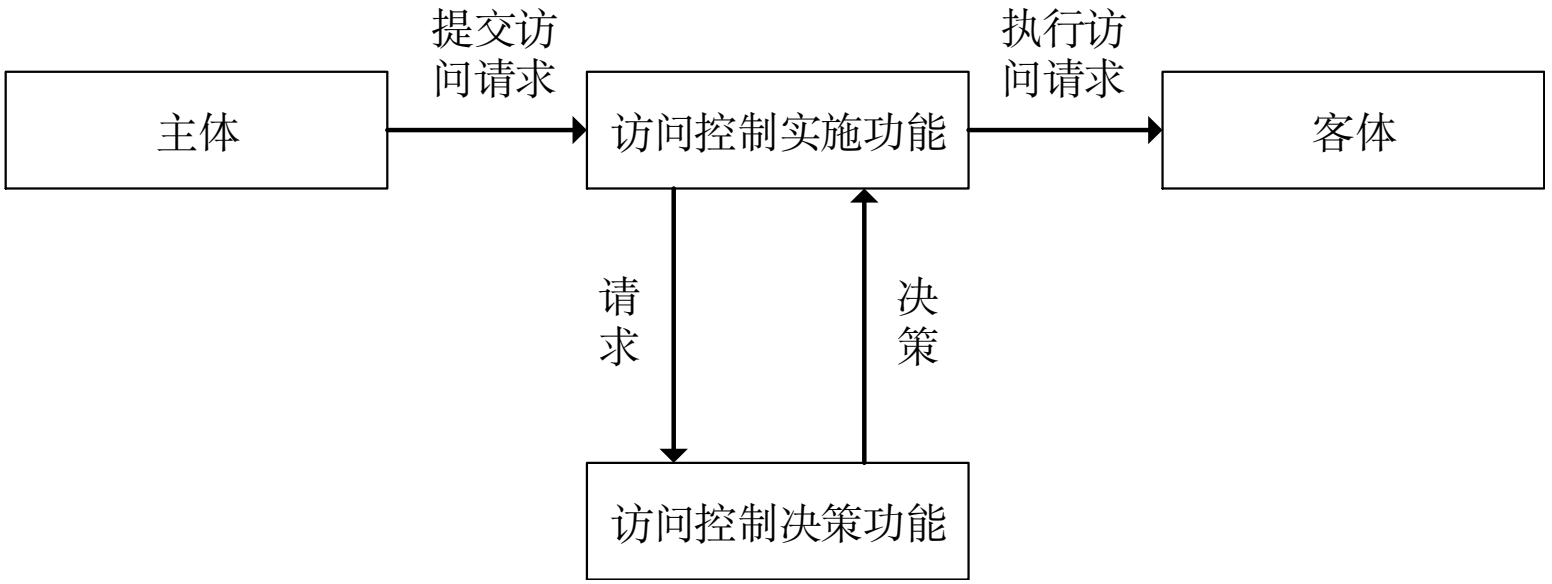
	Mechanism							
Service	Enciph-erment	Digital signature	Access control	Data integrity	Authenti-cation exchange	Traffic padding	Routing control	Notari-zation
Peer entity authentication	Y	Y			Y			
Data origin authentication	Y	Y						
Access control			Y					
Confidentiality	Y						Y	
Traffic flow confidentiality	Y					Y	Y	
Data integrity	Y	Y		Y				
Non-repudiation		Y		Y				Y
Availability				Y	Y			



访问控制模型



访问控制基本原理



访问控制模型	安全性	实现难易	权限管理
DAC	弱	容易	复杂
MAC	强	难	复杂
RBAC	较强	适中	简单



DAC访问控制模型

(1) 自主访问控制是指由用户有权对自身所创建的访问对象(文件、数据表等)进行访问，并可将对这些对象的访问权授予其他用户和从授予权限的用户收回其访问权限。

(2) DAC模型一般采用访问控制矩阵和访问控制列表来存放不同主体的访问控制信息，从而达到对主体访问权限的限制目的。



ACL和优化ACL

– 客体Y	– PID1,r-x	– PID2,rw-	– PID3,--x	– PID4,rwx	–……

– (a)存取控制表

– 文件X		
– PID1 rwx		GROUP5
– * x	GROUP5	--
– PID3 ---		*
– * r--		*

– (b)优化的存取控制表

–



DAC访问控制模型

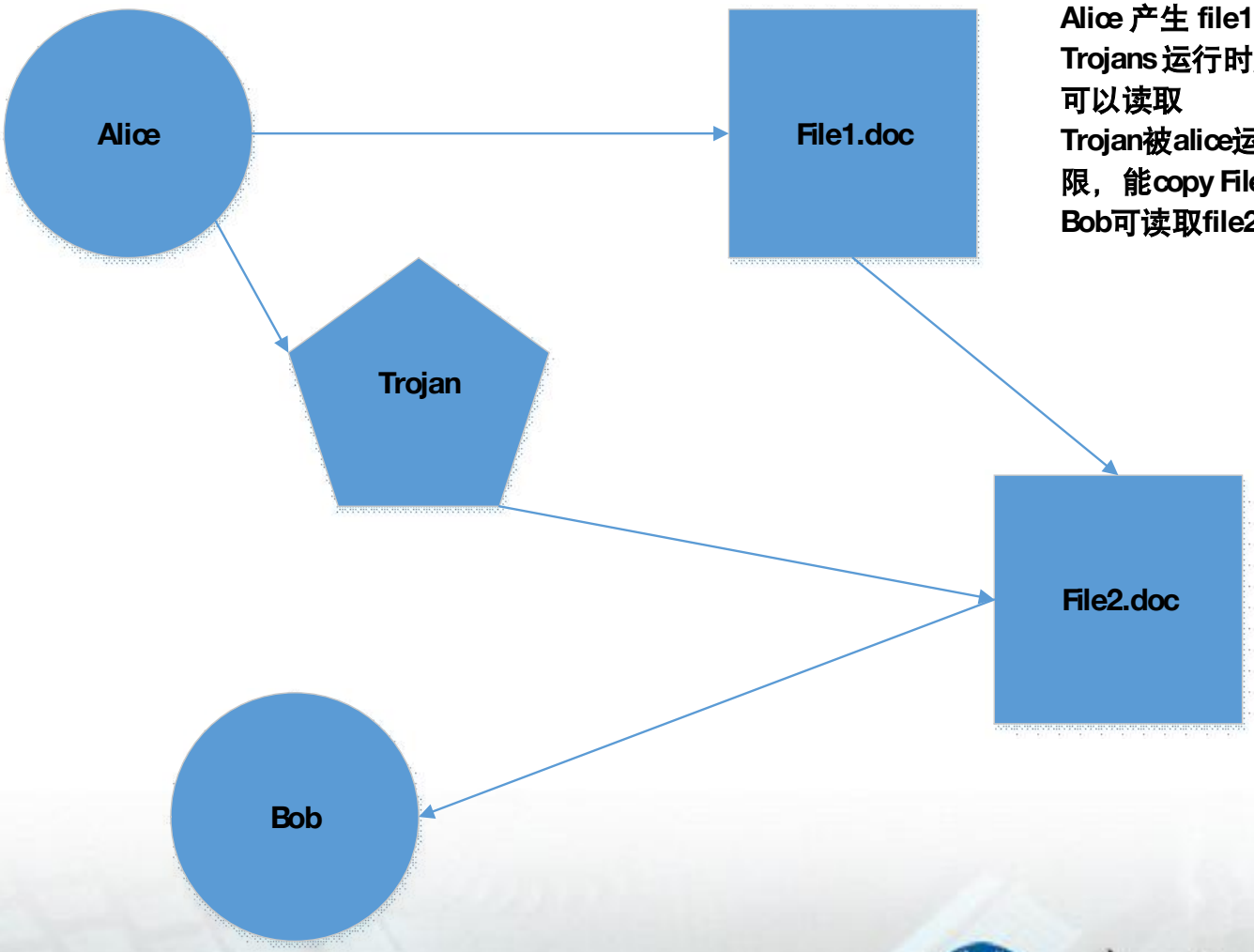
缺点：

（1）主体的权限太大,无意间就可能泄露信息

（2）当用户数量多、管理数据量大时,访问控制矩阵或者ACL 就会很庞大。不易维护

（3）特洛伊木马脆弱





Alice 产生 file1.doc
Trojans 运行时产生file2.doc，授权Bob可以读取
Trojan被alice运行，则具备Alice的权限，能copy File1 到file2.
Bob可读取file2，即读取file1



MAC访控模型

管理员管理访问控制。管理员制定策略，用户不能改变它。策略定义了哪个主体能访问哪个对象。主体获得清楚的标记，对象得到分类标记，或称安全级别

由于安全标记之间的支配关系是满足偏序性质的，可以形成格结构，其中最为经典的是BLP和Biba模型

例如，管理员的访问级别65535，Alice的是100，客人（Guest）是1，有两个文件，file1级别2，file2级别200，这样Alice只能访问file1，客人不能访问file1和file2，管理员两个文件都可以访问。用户的访问级别需要比他想访问的对象的级别高或者相等



基于安全标签的强制访问控制

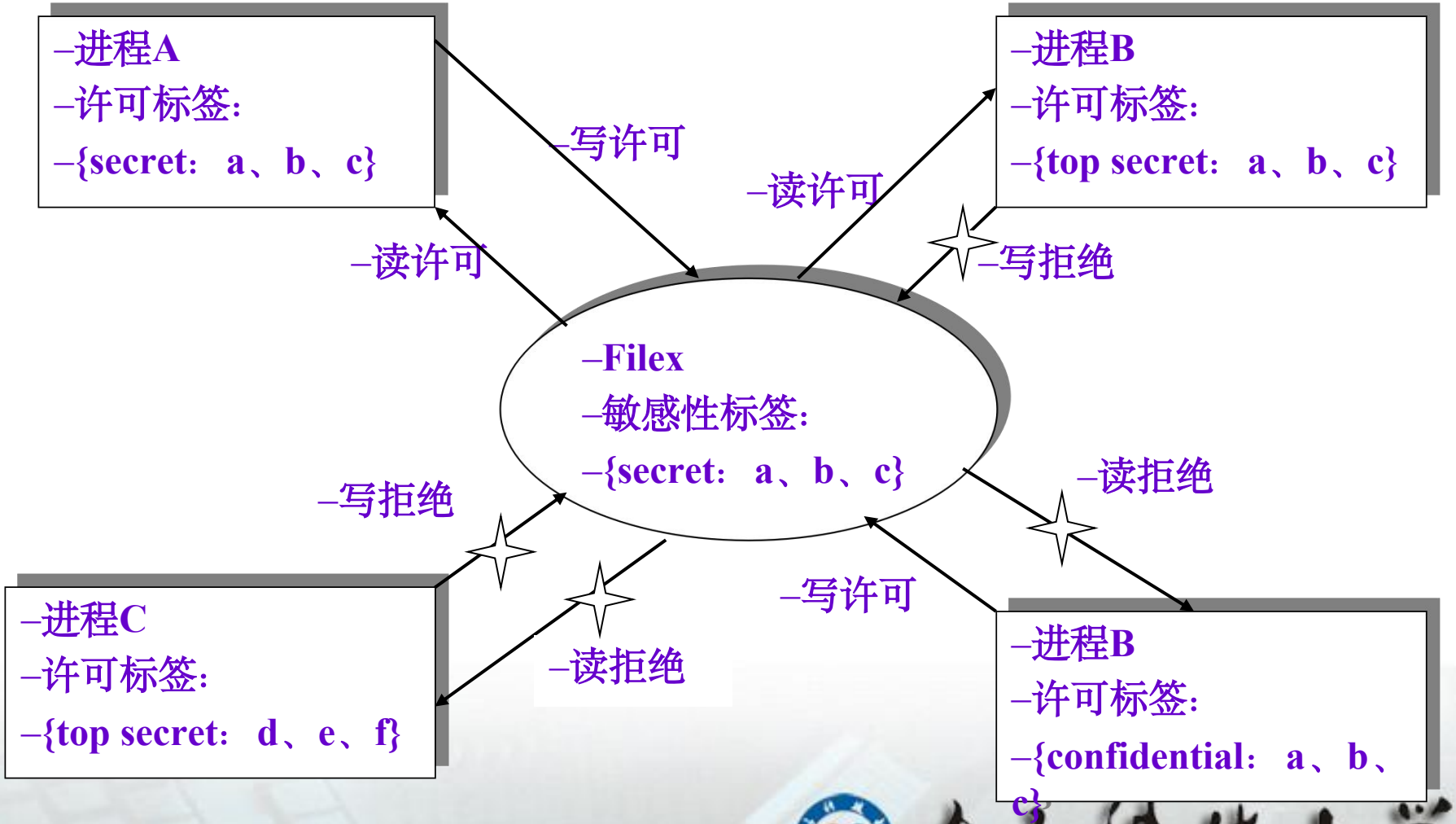
安全系统控制主体对客体的访问基于它们的安全标签的，故应设计标签比较算法，用来判断安全级标签的支配关系，以决定主体对客体的访问权限。一个进程（主体）要想访问客体，其许可标签必须具备：

1）若想要对客体具有写访问权限，主体的安全级别{密级+范畴}必须被客体的安全级别支配、即主体安全等级<客体安全等级，主体的范畴<客体的范畴）。

2）若想要对客体具有读权限，主体的安全级别{安全等级+范畴}必须支配客体的安全级别（主体安全等级＞客体安全等级，主体的范畴＞客体的范畴）。

如果进程（主体）不能够满足上面的任何一条要求，则不能够访问客体。

基于安全标签的强制访问控制



Cla.R



BLP模型

强制访问控制模型：BLP模型被用于保护系统的机密性，防止信息的未授权泄漏。

① 安全级别Level：公开（UC）、秘密（S）、机密（C）、绝密（TS）。它们之间的关系为UC≤S≤C≤TS。

② 范畴Category：为一个类别信息构成的集合，例如｛中国，军事，科技｝。具有该范畴的主体能够访问那些以该范畴子集为范畴的客体。

③ 安全标记Label：由安全级别和范畴构成的二元组<Level，Category>，例如<C，{中国,科技}>。

④ 支配关系dom：安全标记A dom B，当且仅当 $\text{Level}_A \geq \text{Level}_B$，$\text{Category}_A \supseteq \text{Category}_B$。



强制访问控制模型：BLP模型中在为系统中每个保护范围内的主客体都分配了安全标记后，主体对客体的访问行为应满足如下两条安全属性：

① 简单安全属性：主体S可以读客体O，当且仅当 $Label_S$ dom $Label_O$，且S对O有自主型读访问权限。

② *安全属性：主体S可以写客体O，当且仅当 $Label_O$ dom $Label_S$，且S对O具有自主型写权限。

从信息流角度看，上述两条读/写操作所应遵循的安全属性阻止了信息从高安全级别流入低安全级别，且使得信息“仅被需要知悉的人所知悉”，因此，能够有效地确保数据的机密性。



Biba模型

强制访问控制模型：Biba模型是第一个关注完整性的访问控制模型，用于防止用户或应用程序等主体未授权地修改重要的数据或程序等客体。

① 完整性级别Level：代表了主/客体的可信度。完整性级别高的主体比完整性级别低的主体在行为上具有更高的可靠性；完整性级别高的客体比完整性级别低的客体所承载的信息更加精确和可靠。

② 范畴Category：若范畴$\text{Category}_A \supseteq \text{Category}_B$，则A能写入B；否则，A不能写入B。

③ 完整性标记Label：由完整性级别和范畴构成的二元组<Level，Category>。

④ 支配关系dom：完整性标记A dom B，当且仅当$\text{Level}_A \geq \text{Level}_B$，$\text{Category}_A \supseteq \text{Category}_B$。

电子科技大学



强制访问控制模型： Biba模型的严格完整性策略是BLP模型的对偶，也是不特别指明情况下所谓的Biba模型。它应满足如下安全属性。

① 完整性特性：主体S能够写入客体O，当且仅当 $Label_S$ dom $Label_O$。

② 调用特性：主体S_1能够调用主体S_2，当且仅当 $Label_{S1}$ dom $Label_{S2}$。

③ 简单完整性条件：主体S能够读取客体O，当且仅当$Label_O$ dom $Label_S$。

基于上述三条安全属性，信息只能从高完整性级别的主客体流向低完整性级别的主客体，从而有效避免了低完整性级别的主客体对高安全级别主客体的完整性的“污染”。

Cla.R



RBAC模型

管理员定义一系列角色（roles）并把它们赋予主体。系统进程和普通用户可能有不同的角色。设置对象为某个类型，主体具有相应的角色就可以访问它

需要注意的是，具体实现的时候，往往会组合使用这几个模型。

例如：Windows NT使用内建的组实现了类似RBAC模型，如Power Users，Server Operators，Backup Operators。管理员可以根据作业的行为增加额外的角色。

拥有适当权限的用户可以分享资源，如文件和打印机，而且与DAC模型相应的，自主决定给与其它用户和组访问权。



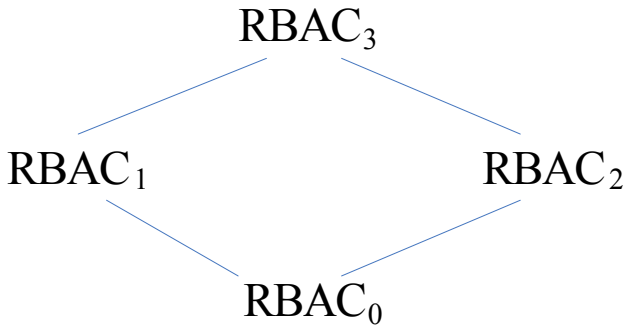
基于角色的访问控制：标准RBAC模型包括了RBAC0~3四个模型。

① RBAC0模型（Core RBAC），定义了用户、角色、会话和访问权限等要素。

② RBAC1（Hierarchal RBAC）在RBAC0的基础上引入了角色继承的概念。

③ RBAC2（Constraint RBAC）增加了角色之间的约束条件，例如互斥角色、最小权限等。

④ RBAC3（Combines RBAC）是RBAC1和RBAC2的综合，探讨了角色继承和约束之间的关系。



基于角色的访问控制：CoreRBAC。

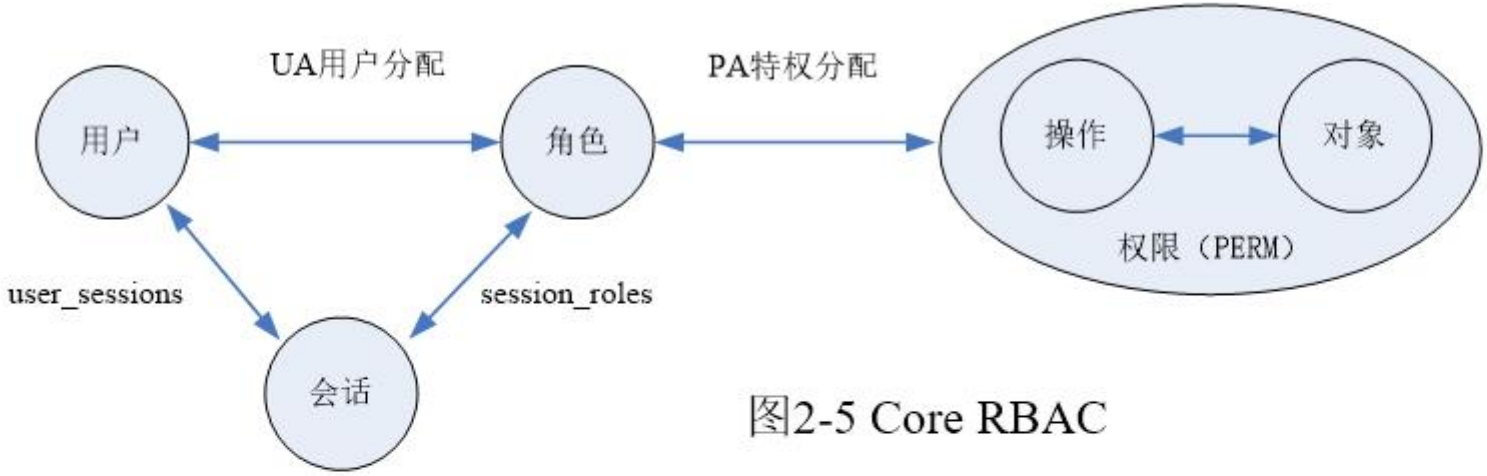


图2-5 Core RBAC

① 用户是访问控制的主体，可以发起访问操作请求。
② 对象是访问控制的客体，指系统中受访问控制机制保护的资源。
③ 操作是指对象上能够被执行的一组访问操作。
④ 权限是指对象及其上指定的一组操作。
⑤ 角色是权限分配的载体，是一组有意义的权限集合。
⑥ 会话用于维护用户和角色之间的动态映射关系。



基于角色的访问控制：CoreRBAC。

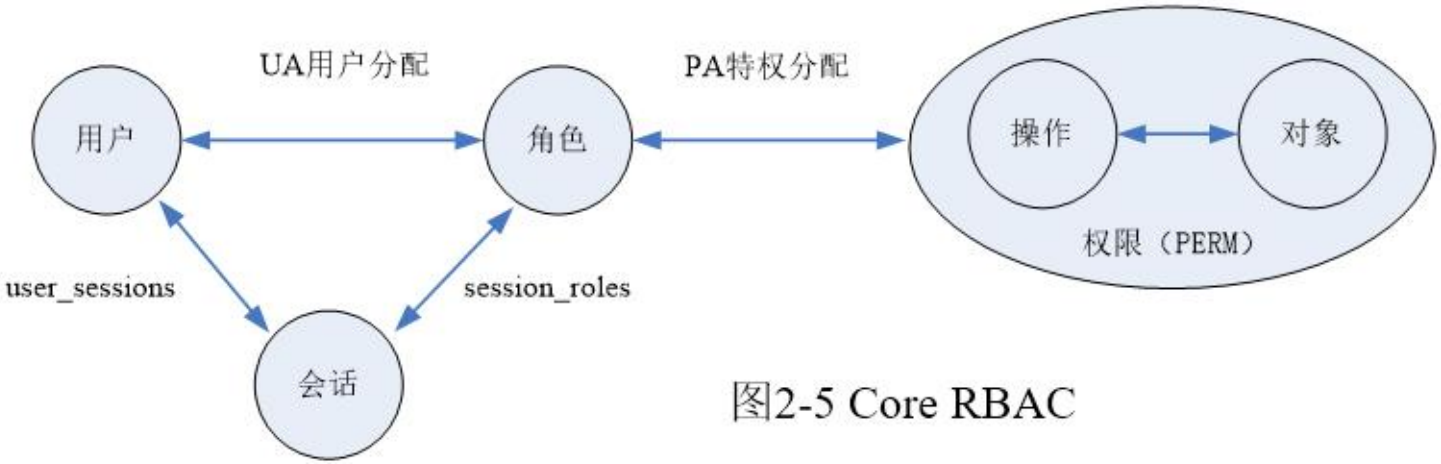


图2-5 Core RBAC

① UA用户分配：用户和角色之间是多对多的映射关系，记录了管理员为用户分配的所有角色。

② PA特权分配：角色与权限之间也是多对多的映射关系，记录了管理员为角色分配的所有权限。

③ user_sessions：用户与会话之间的一对多映射关系。即一个用户可通过登录操作开启一个或多个会话，而每个会话只对应一个用户。

④ session_roles：会话与角色之间的多对多关系。即用户可以在一个会话中激活多个角色，而一个角色也可以在多个会话中被激活。



基于属性的访问控制：通过安全属性来定义授权，并实施访问控制。由于安全属性可以由不同的属性权威分别定义和维护，所以具备较高的动态性和分散性，能够较好地适应开放式的环境。具体地，它包括如下几个重要概念：

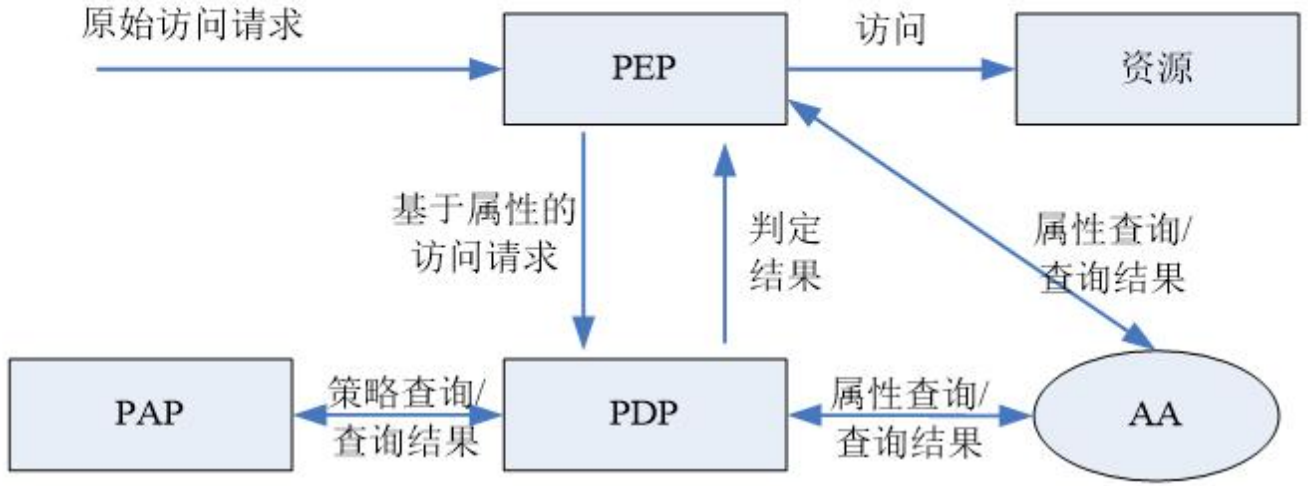
① 实体：系统中存在的主体、客体，以及权限和环境。

② 环境：指访问控制发生时的系统环境。

③ 属性：用于描述上述实体的安全相关信息。它通常由属性名和属性值构成，又可分为以下几类：

- ✓ 主体属性
- ✓ 权限属性
- ✓ 环境属性

基于属性的访问控制：



① AA为属性权威，负责实体属性的创建和管理，并提供属性的查询。

② PAP为策略管理点，负责访问控制策略的创建和管理，并提供策略的查询。

③ PEP为策略执行点，负责处理原始访问请求，查询AA中的属性信息生成基于属性的访问请求，并将其发送给PDP进行判定，然后根据PDP的判定结果实施访问控制。

④ PDP为策略判定点，负责根据PAP中的策略集对基于属性的访问请求进行判定，并将判定结果返回PEP。



问题分析

早期访问控制模型和技术在大数据应用场景下主要存在三方面问题：

安全管理员的授权管理难度更大。	严格的访问控制策略难以适用。	外包存储环境下无法使用。
• 工作量大 • 领域知识匮乏	• 访问需求无法预知 • 访问需求动态变化	• 数据所有者不具备海量存储能力 • 数据所有者不具备构建可信引用监控机的能力



访问控制安全模型

Lampson访问控制矩阵模型

Graham-Dening Model

Harrison-Ruzzo-Ullman Results

Take-Grant systems



(1)Lampson访问控制矩阵模型

客体被认为是存储器，访问控制检查不基于存储的内容值而是基于系统的状态，

系统状态中与安全相关的因素概括在访问矩阵中，由三元组(S,O,M)决定，访问权限集包含读、写、追加、修改和执行等。系统中状态的改变取决于访问矩阵M的改变，一个独立的状态机构成一个系统，因而，访问矩阵也称为系统的“保护状态”。系统中所有主体对客体的访问均由“引用监视器”控制，它的任务是确保只有那些在访问矩阵中获得授权的操作才被允许执行。



(2)Graham-Denning模型

此模型的保护性能更具有一般性，对主体集合S、客体集合O、权力集合R和访问控制矩阵A进行操作。主体有一行，每个主体及所有客体都有一列，一个主体对于另一个主体或对于一个客体的权力用矩阵元素的内容来表示。

对于每个客体，标明为“拥有者”的主体有特殊权力；对于每个主体，标明为“控制者”的另一主体有特殊权力。本模型中，设计了8个基本保护权，构造一个保护系统的访问控制机制模型所必需的性质，这些权力被表示成主体能够发出的命令，作用于其他主体或客体。



Graham-Denning Access Model

Table 7-2 Protection System Commands

Command	Pre-Condition	Effect
Create object *o*	—	Add column for *o* in A; place *owner* in A[*x*,*o*]
Create subject *s*	—	Add row for *s* in A; place *control* in A[*x*,*o*]
Delete object *o*	*Owner* in A[*x*,*o*]	Delete column *o*
Delete subject *s*	*Control* in A[*x*,*s*]	Delete row *s*
Read access right of *s* on *o*	*Control* in A[*x*,*s*] or *owner* in A[*x*,*o*]	Copy A[*s*,*o*] to *x*
Delete access right *r* of *s* on *o*	*Control* in A[*x*,*s*] or *owner* in A[*x*,*o*]	Remove *r* from A[*s*,*o*]
Grant access right *r* to *s* on *o*	*Owner* in A[*x*,*o*]	Add *r* to A[*s*,*o*]
Transfer access right *r* or *r*∗ to *s* on *o*	*r*∗ in A[*x*,*o*]	Add *r* or *r*∗ to A[*s*,*o*]

- Model operates on a set of subjects, objects, rights and an access matrix
- One row for each subject, one column for each object
- Elements of the matrix show rights for subject or object in that cell
- Owner has special rights
- Controller has special rights
- Transferable right denoted r*, non-transferable right denoted r



Graham-Denning Access Model

	BIBLIOG	TEMP	F	HELP.TXT	C_COMP	LINKER	SYS_CLOCK	PRINTER
USER A	ORW	ORW	ORW	R	X	X	R	W
USER B	R	—	—	R	X	X	R	W
USER S	RW	—	R	R	X	X	R	W
USER T	—	—	—	R	X	X	R	W
SYS_MGR	—	—	—	RW	OX	OX	ORW	O
USER_SVCS	—	—	—	O	X	X	R	W

Figure 6-13 Access Control Matrix



Graham-Denning

Set of subjects (processes, users)

Set of objects

Matrix of rights (read, write, own, exec)

Owns means can add and revoke any rights



Example: process and file

	file 1	file 2	process 1	process 2
process 1	read, write, own	read	read, write, execute, own	write
process 2	append	read, own	read	read, write, execute, own



Example: LAN rights

host names	*telegraph*	*nob*	*toadflax*
telegraph	own	ftp	ftp
nob		ftp, nfs, mail, own	ftp, nfs, mail
toadflax		ftp, mail	ftp, nfs, mail, own

Telegraph is an ftp client

nob and toadflax exchange mail

电子科技大学



Harrison-Ruzzo-Ullman

- HRU similar to Graham-Denning model
- Based on commands where each command involves conditions and primitive operations
- Command has structure like a procedure with parameters o1…ok

```
command name(o1,o2,. . . ,ok)
    if      r1 in A[s1,o1] and
            r2 in A[s2,o2] and
            . . .
            rm in A[sm,om]
    then
            op1
            op2
            . . .
            opn
end
```



Harrison-Ruzzo-Ullman(2)

	Objects					
Subjects	S_1	S_2	S_3	O_1	O_2	O_3
S_1	Control	Own Suspend Resume		Own	Own	Read Propagate
S_2		Control			Extend	Own
S_3			Control	Read, Write	Write	Read
...						

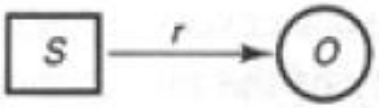
Figure 7-8 Access Matrix in HRU Model

- In HRU every subject is an object
- Primitives op are similar to Graham-Denning model
  - Create subject s
  - Create object o
  - Destroy subject s
  - Destroy object o
  - Enter right r into A[s,o]
  - Delete right r from A[s,o]

Take-Grant Systems

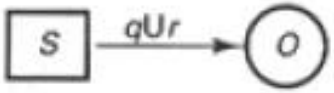
Creation of an object



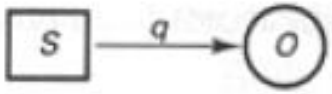


Create(o, r): A new node with label o is added to the graph. From s to o there is a directed edge with label r, denoting the rights of s on o.

Revocation of a right



Becomes

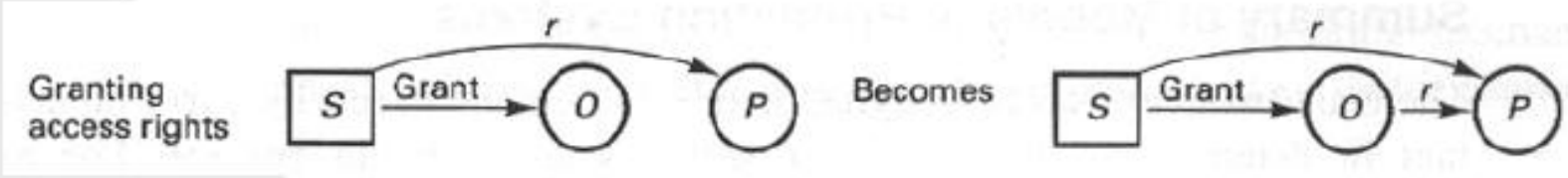


Revoke(o, r): The rights r are revoked from s on o. The edge from s to os was labeled q U r,; the label is replaced by q.

- Four primitive operations: create, revoke, take and grant
- Create and revoke similar to Graham-Denning and HRU models

电子科技大学

Take-Grant Systems (2)



Grant(o,p,r): Subjects s grants to o access rights r on p. A specific right is a grant

Subject s can grant to o access rights r on p iff s has grant right on o, and s has r rights on p.

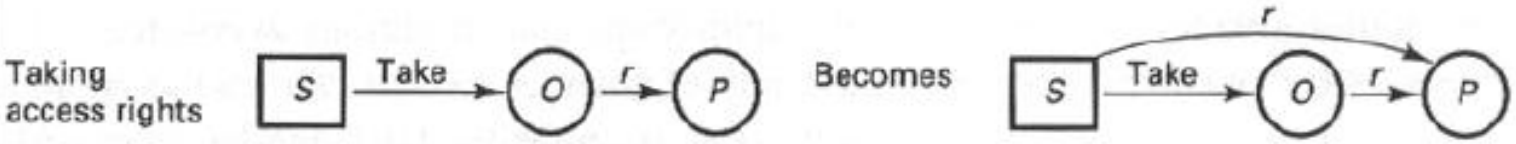
Thus s can grant (share) any of its rights with o, as long as s has the right to grant privileges to o.

An edge from o to p is added, with label r

电子科技大学



Take-Grant Systems (3)



Take(o,p,r): Subject s takes from o access right r on p. A specific right is take.

Subject s can take from o access rights r on p iff s has take right on o, and o has r rights on p

S can take any rights o has, as long as s has the right to take privileges from o

An edge from s to p is added with label r